

Fundación Politécnico Minuto de Dios

PRÁCTICA SOBRE ANÁLISIS Y GESTIÓN DE LOGS E INCIDENTES DE SEGURIDAD

Materia: Monitoreo de la Seguridad Informática

Estudiante: Miguel Angel Peralta Cano

Docente: José Luis Rodríguez Cortés

9 de junio de 2026

Resumen

El presente documento constituye un portafolio de evidencias técnico sobre la conceptualización, monitoreo y respuesta a incidentes utilizando registros del sistema (logs). Se aborda la problemática de la seguridad de la información desde una perspectiva eminentemente práctica, documentando la instalación y configuración de la estación de trabajo CyberOps. Mediante el uso de herramientas de línea de comandos en Linux (tales como `cat`, `tail`, y `journalctl`), se auditan eventos del sistema operativo y de red, diagnosticando y rastreando anomalías. Finalmente, se aplica la teoría a un escenario simulado de infección por gusano informático y ataque de Denegación de Servicio (DDoS), estableciendo un protocolo estructurado de respuesta a incidentes apoyado en herramientas de ciberseguridad, basado en las fases de Preparación, Detección, Contención, Erradicación y Recuperación.

Índice

1. Introducción	3
2. Desarrollo de la Actividad Práctica	3
2.1. Práctica 1: Instalación de la máquina virtual de la estación de trabajo CyberOps	3
2.2. Práctica 2: Lectura de registros (Logs) del servidor	5
2.2.1. Inspección Básica y Filtrado (cat, more, less, tail)	5
2.2.2. Monitorización Activa: Trazabilidad en Tiempo Real	7
2.2.3. Syslog y Privilegios del Sistema	8
2.2.4. La Evolución: Archivos de registro y Journalctl	10
2.3. Práctica 3: Manejo de Incidentes (Estudio de Caso Analítico)	12
2.3.1. Fase 1: Preparación (Ingeniería Preventiva)	13
2.3.2. Fase 2: Detección y Análisis (Visibilidad y Triage)	13
2.3.3. Fase 3: Contención, Erradicación y Recuperación (Resolución Táctica)	14
2.3.4. Fase 4: Actividad Posterior al Incidente (Auditoría Forense)	14
3. Conclusiones	15

1. Introducción

En el presente portafolio se recopilan todas las actividades y evidencias operativas desarrolladas durante la práctica de análisis de logs y gestión de incidentes en el entorno controlado de la máquina virtual CyberOps.

¿Cuál es el propósito del portafolio?

El propósito fundamental de este documento es registrar, organizar y justificar de manera técnica el paso a paso de la práctica de laboratorio. Sirve como un expediente demostrativo de la asimilación de habilidades prácticas: la ejecución precisa de comandos de Linux para la lectura forense de registros, la correlación de eventos críticos y la arquitectura de soluciones tácticas ante incidentes de ciberseguridad. Representa el puente necesario entre la teoría de los marcos de control y la trinchera técnica operativa.

¿Cuál es su importancia?

Su importancia radica en la capacidad de forzar una reflexión analítica sobre la instrumentación utilizada. En seguridad informática, operar en la línea de comandos sin comprender el subtexto es ineficaz; es indispensable argumentar *por qué* una herramienta específica (como `less` vs `more`) ahorra minutos vitales durante un ataque. Los registros (logs) son la materia prima indiscutible de cualquier autopsia digital; comprenderlos y estructurar un plan de respuesta en fases asegura que la organización no dependa de la improvisación frente a una crisis.

Justificación del Formato de Documentación

Este informe técnico ha sido maquetado y compilado utilizando el sistema de composición de textos $\text{\LaTeX}$. La elección de esta herramienta se fundamenta en su estatus como estándar de facto para la redacción de documentos científicos e ingenieriles. $\text{\LaTeX}$ garantiza una presentación estructurada, modular y altamente profesional, con un manejo matemático del espaciado y una renderización exacta de los bloques de código y salidas de terminal (CLI). Estas características aseguran que los reportes de auditoría y respuesta a incidentes sean pulcros, legibles y cumplan con los estándares visuales de la industria corporativa.

2. Desarrollo de la Actividad Práctica

2.1. Práctica 1: Instalación de la máquina virtual de la estación de trabajo CyberOps

Para iniciar el entorno de simulación, se procedió con la instalación de Oracle Virtual-Box y la importación de la imagen (*appliance*) en formato OVA de la máquina CyberOps Workstation. Durante este proceso, se impuso la reinicialización de la dirección MAC de la interfaz de red, una práctica vital para evitar colisiones de enrutamiento y suplantaciones de identidad (ARP Spoofing) en laboratorios de red.

Tras el arranque del sistema invitado, se inició sesión utilizando las credenciales asignadas (*analista / cyberops*). En el entorno gráfico (GUI), se exploró el menú de aplicaciones **CyberOps**, el cual agrupa herramientas nativas para ciberseguridad: emuladores de terminal de alta respuesta, navegadores web para consultas OSINT (Firefox), y analizadores

de protocolos de red.

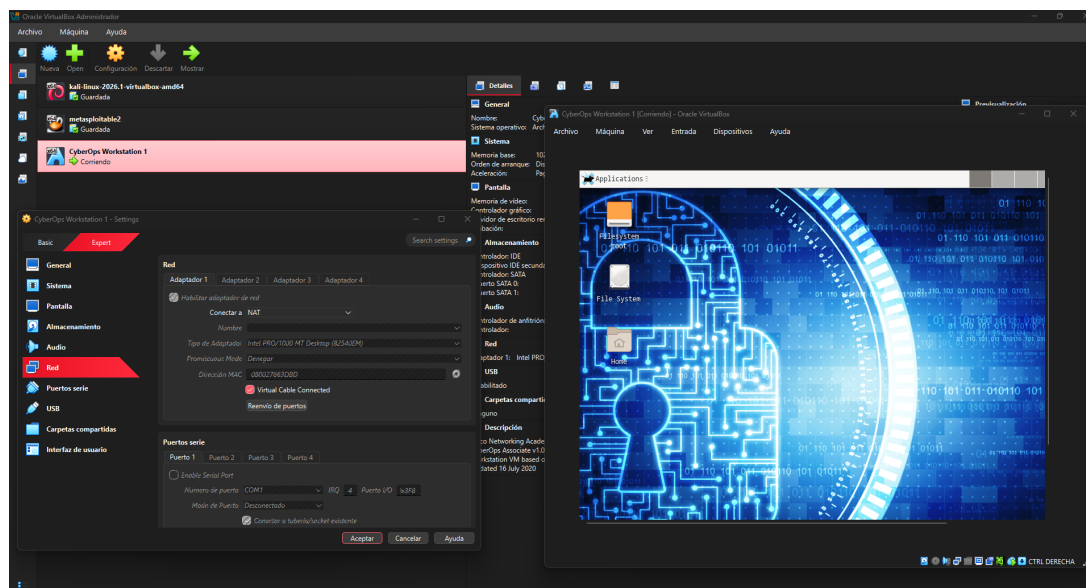


Figura 1: Pantalla de inicio e interfaz de la máquina CyberOps Workstation, evidenciando el entorno aislado.

Acto seguido, se abrió una terminal para auditar la configuración de red asignada dinámicamente o estáticamente mediante el comando `ip address`.

```
[analyst@secOps Desktop]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:66:3d:bd brd ff:ff:ff:ff:ff:ff
   inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic enp0s3
       valid_lft 85929sec preferred_lft 85929sec
   inet6 fd17:625c:f037:2:a00:27ff:fe66:3dbd/64 scope global dynamic mngtmpaddr noprefixroute
       valid_lft 85929sec preferred_lft 13929sec
   inet6 fe80::a00:27ff:fe66:3dbd/64 scope link
       valid_lft forever preferred_lft forever
```

Figura 2: Verificación de la pila TCP/IP y dirección IP asignada a la interfaz de la máquina virtual.

Reflexión: ¿Cuáles son las ventajas y desventajas de usar una máquina virtual?

- **Ventajas y Casos de Uso Reales:** La virtualización otorga aislamiento criptográfico y de memoria (*Sandboxing*). En la vida real, los analistas de malware (Malware Analysts) ejecutan virus destructivos (como Ransomware) exclusivamente dentro de máquinas virtuales. Si el sistema colapsa, no infecta el equipo anfitrión (*Host*) y la máquina puede ser restaurada a su estado original en segundos mediante "Snapshots" (instantáneas). Además, se utilizan para desplegar *Honeypots* (sistemas trampa) de bajo costo para despistar atacantes.
- **Desventajas y Consideraciones Técnicas:** La principal limitante es el sobre costo de recursos computacionales (*Overhead*). El anfitrión debe dividir su memoria

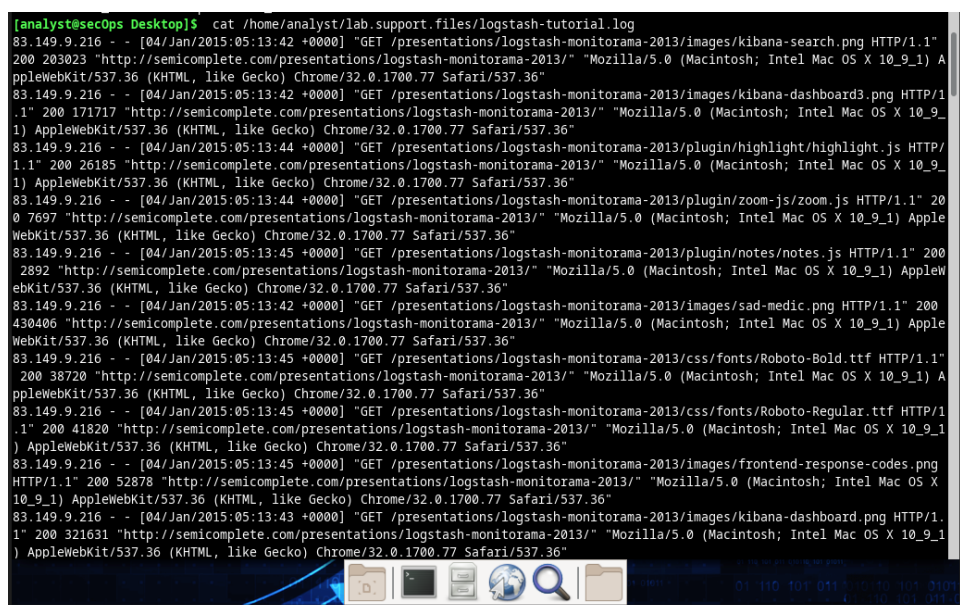
RAM, núcleos de CPU y almacenamiento físico. En entornos empresariales de alta densidad, una mala asignación de recursos (*Resource Contention*) puede generar cuellos de botella (I/O Bottlenecks), provocando lentitud masiva tanto en el hipervisor como en los sistemas invitados.

2.2. Práctica 2: Lectura de registros (Logs) del servidor

Los archivos de registro (Logs) son el sistema nervioso central del monitoreo informático. Representan secuencias inmutables de eventos. En esta práctica, se exploró el archivo `logstash-tutorial.log` utilizando herramientas fundamentales de UNIX/Linux, evaluando la idoneidad de cada una para distintos escenarios de ciberseguridad.

2.2.1. Inspección Básica y Filtrado (`cat`, `more`, `less`, `tail`)

Se inició utilizando el comando de concatenación `cat`. Al invocarlo, el motor del sistema operativo volcó inmediatamente todo el búfer de texto en la pantalla estándar (`stdout`).



```
[analyst@secOps Desktop]$ cat /home/analyst/lab.support.files/logstash-tutorial.log
83.149.9.216 - - [04/Jan/2015:05:13:42 +0000] "GET /presentations/logstash-monitorama-2013/images/kibana-search.png HTTP/1.1" 200 203023 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:42 +0000] "GET /presentations/logstash-monitorama-2013/images/kibana-dashboards.png HTTP/1.1" 200 171717 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:44 +0000] "GET /presentations/logstash-monitorama-2013/plugin/highlight/highlight.js HTTP/1.1" 200 26185 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:44 +0000] "GET /presentations/logstash-monitorama-2013/plugin/zoom-js/zoom.js HTTP/1.1" 200 7697 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:45 +0000] "GET /presentations/logstash-monitorama-2013/plugin/notes/notes.js HTTP/1.1" 200 2892 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:42 +0000] "GET /presentations/logstash-monitorama-2013/images/sad-medic.png HTTP/1.1" 200 430406 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:45 +0000] "GET /presentations/logstash-monitorama-2013/css/fonts/Roboto-Bold.ttf HTTP/1.1" 200 38720 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:45 +0000] "GET /presentations/logstash-monitorama-2013/css/fonts/Roboto-Regular.ttf HTTP/1.1" 200 41820 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:45 +0000] "GET /presentations/logstash-monitorama-2013/images/frontend-response-codes.png HTTP/1.1" 200 52878 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
83.149.9.216 - - [04/Jan/2015:05:13:43 +0000] "GET /presentations/logstash-monitorama-2013/images/kibana-dashboards.png HTTP/1.1" 200 321631 "http://semicomplete.com/presentations/logstash-monitorama-2013/" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_9_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/32.0.1700.77 Safari/537.36"
```

Figura 3: Volcado ininterrumpido del archivo mediante `cat`.

Aplicación Real: `cat` es pésimo para logs grandes porque inunda la terminal. Sin embargo, en la vida real, se utiliza combinado con redirecciones (`>`) o concatenado con el comando `grep` para extraer rápidamente información, por ejemplo: `cat /var/log/auth.log | grep "Failed password"` para cazar intentos de fuerza bruta.

Posteriormente, se introdujo el paginador `more`. Esto frenó el flujo de texto, permitiendo leer el registro bloque a bloque.

¿Cuál es el inconveniente de usar `more`? El obstáculo arquitectónico de `more` es su unidireccionalidad. Solo permite avanzar (Scroll Down). En un análisis forense, si el ingeniero detecta una IP maliciosa y accidentalmente presiona la barra espaciadora, no puede retroceder para revisar el contexto previo del ataque sin tener que cerrar la herramienta y volver a empezar.

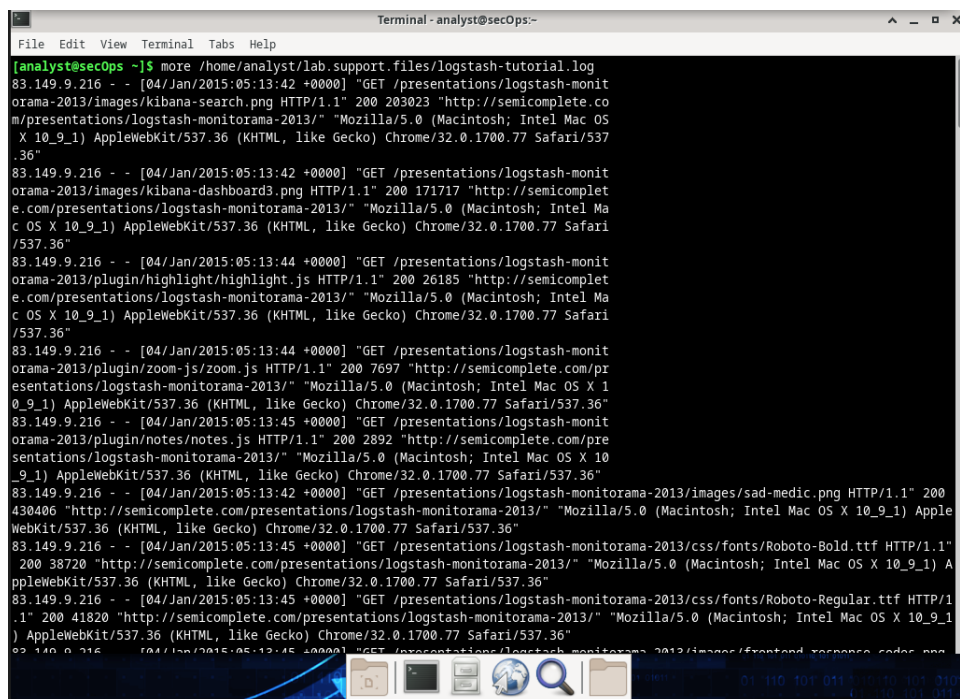


Figura 4: Visualización paginada y unidireccional con more.

Para mitigar esta ineficiencia, se desplegó **less**. Esta herramienta no carga el archivo completo en la memoria RAM, lo que la hace ultrarrápida incluso con logs de varios Gigabytes.

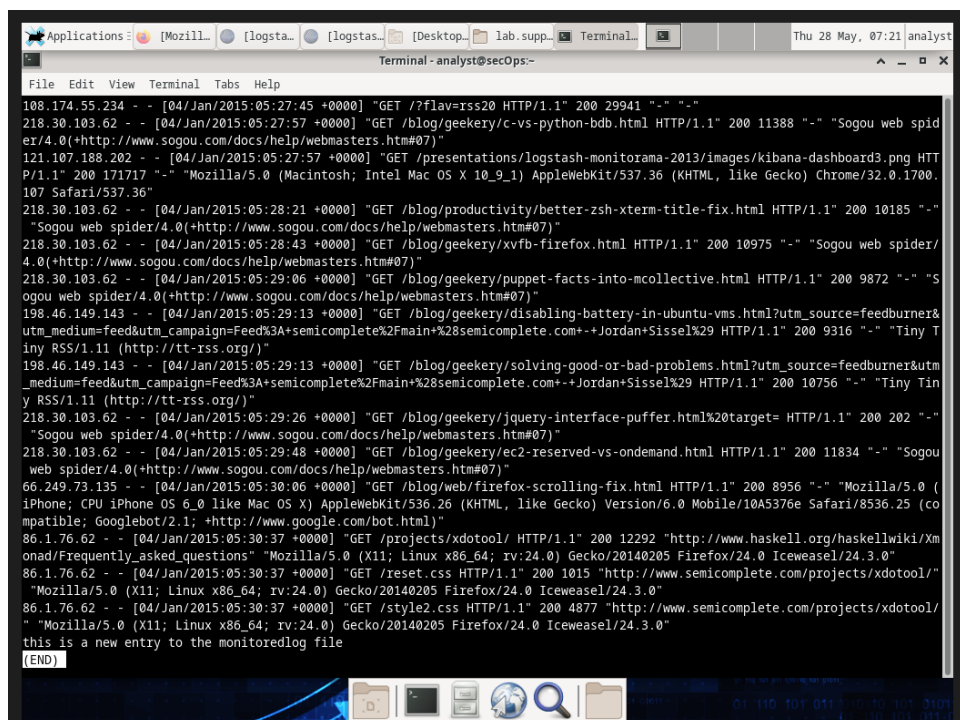
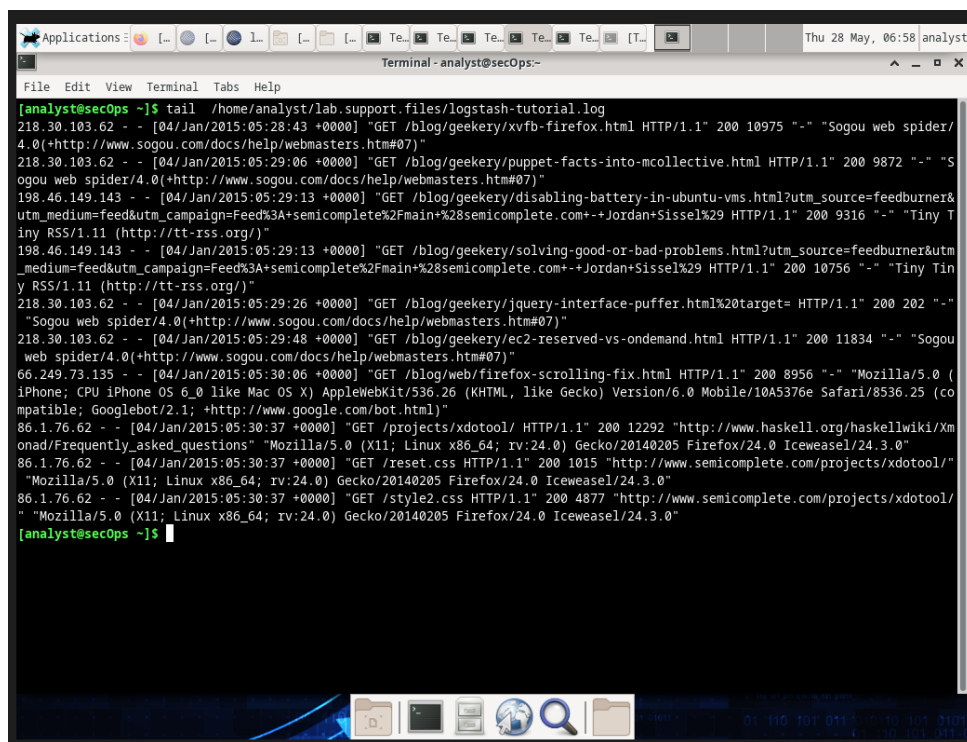


Figura 5: Navegación dinámica y bidireccional usando less.

Aplicación Real: **less** permite búsquedas con expresiones regulares interactivas escribiendo / seguido de una palabra (ej. /ERROR). Es la herramienta preferida en los NOC

(Network Operations Centers) para buscar transacciones perdidas sin colgar el servidor.

Finalmente, el comando `tail` resolvió la necesidad de ver únicamente las transacciones más recientes (por defecto, las últimas 10 líneas).



```
[analyst@secOps ~]$ tail /home/analyst/lab.support.files/logstash-tutorial.log
218.30.103.62 - - [04/Jun/2015:05:28:43 +0000] "GET /blog/geekery/xvfb-firefox.html HTTP/1.1" 200 10975 "-" "Sogou web spider/4.0(+http://www.sogou.com/docs/help/webmasters.htm#07)"
218.30.103.62 - - [04/Jun/2015:05:29:06 +0000] "GET /blog/geekery/puppet-facts-into-mcollective.html HTTP/1.1" 200 9872 "-" "Sogou web spider/4.0(+http://www.sogou.com/docs/help/webmasters.htm#07)"
198.46.149.143 - - [04/Jun/2015:05:29:13 +0000] "GET /blog/geekery/disabling-battery-in-ubuntu-vm.html?utm_source=feedburner&utm_medium=feed&utm_campaign=Feed%3A+semicomplete%2Fmain+%28semicomplete.com+-+Jordan+Sissel%29 HTTP/1.1" 200 9316 "-" "Tiny Tiny RSS/1.11 (http://tt-rss.org/)"
198.46.149.143 - - [04/Jun/2015:05:29:13 +0000] "GET /blog/geekery/solving-good-or-bad-problems.html?utm_source=feedburner&utm_medium=feed&utm_campaign=Feed%3A+semicomplete%2Fmain+%28semicomplete.com+-+Jordan+Sissel%29 HTTP/1.1" 200 10756 "-" "Tiny Tiny RSS/1.11 (http://tt-rss.org/)"
218.30.103.62 - - [04/Jun/2015:05:29:26 +0000] "GET /blog/geekery/jquery-interface-puffer.html%20target= HTTP/1.1" 200 202 "-" "Sogou web spider/4.0(+http://www.sogou.com/docs/help/webmasters.htm#07)"
218.30.103.62 - - [04/Jun/2015:05:29:48 +0000] "GET /blog/geekery/ec2-reserved-vs-ondemand.html HTTP/1.1" 200 11834 "-" "Sogou web spider/4.0(+http://www.sogou.com/docs/help/webmasters.htm#07)"
66.249.73.135 - - [04/Jun/2015:05:30:06 +0000] "GET /blog/web/firefox-scrolling-fix.html HTTP/1.1" 200 8956 "-" "Mozilla/5.0 (iPhone; CPU iPhone OS 6_0 like Mac OS X) AppleWebKit/536.26 (KHTML, like Gecko) Version/6.0 Mobile/10A5376e Safari/8536.25 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)"
86.1.76.62 - - [04/Jun/2015:05:30:37 +0000] "GET /projects/xdotool/ HTTP/1.1" 200 12292 "http://www.haskell.org/haskellwiki/Xmonad/Frequently_asked_questions" "Mozilla/5.0 (X11; Linux x86_64; rv:24.0) Gecko/20140205 Firefox/24.0 Iceweasel/24.3.0"
86.1.76.62 - - [04/Jun/2015:05:30:37 +0000] "GET /reset.css HTTP/1.1" 200 1015 "http://www.semicomplete.com/projects/xdotool/" "Mozilla/5.0 (X11; Linux x86_64; rv:24.0) Gecko/20140205 Firefox/24.0 Iceweasel/24.3.0"
86.1.76.62 - - [04/Jun/2015:05:30:37 +0000] "GET /style2.css HTTP/1.1" 200 4877 "http://www.semicomplete.com/projects/xdotool/" "Mozilla/5.0 (X11; Linux x86_64; rv:24.0) Gecko/20140205 Firefox/24.0 Iceweasel/24.3.0"
[analyst@secOps ~]$
```

Figura 6: Extracción de las últimas transacciones registradas usando `tail`.

2.2.2. Monitorización Activa: Trazabilidad en Tiempo Real

Para escenarios críticos, un registro estático es insuficiente. Se dividió la pantalla en dos terminales: en la primera se ejecutó el comando de seguimiento `tail -f`, y en la segunda se inyectó una cadena de texto manual mediante `echo` redirigida al archivo monitoreado.

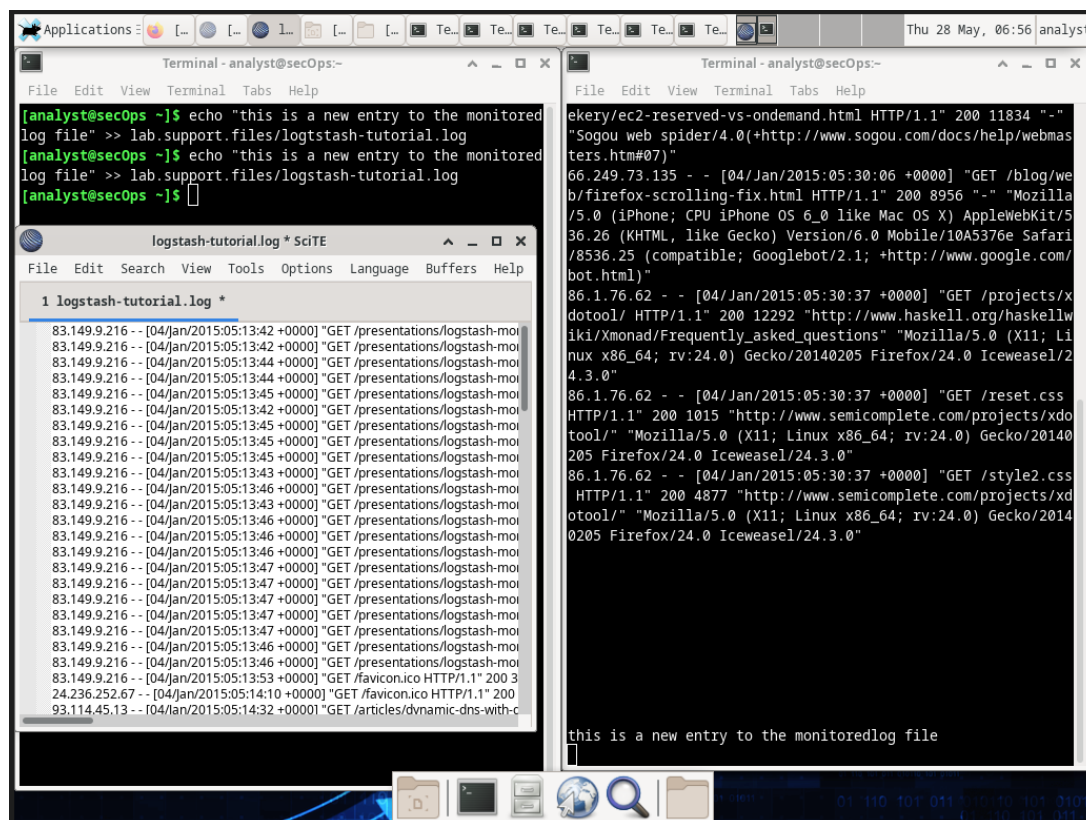


Figura 7: Prueba de concepto de monitorización en vivo capturando escrituras en tiempo real.

¿Qué es diferente en la salida de tail y tail -f? Explique.

El comando `tail` tradicional es *post-mortem*: lee el estado del archivo en ese milisegundo y cierra el proceso. Por el contrario, el modificador `-f` (follow) mantiene el descriptor del archivo (File Descriptor) abierto en la memoria RAM. En un entorno real de producción corporativa, `tail -f /var/log/nginx/access.log` le permite al administrador observar un ataque de inyección SQL (SQLi) o un escaneo de vulnerabilidades web en el instante exacto en que los paquetes HTTP están golpeando el servidor web, habilitando una respuesta instantánea.

2.2.3. Syslog y Privilegios del Sistema

Se exploró la ubicación estándar de registros en Linux: `/var/log`. Al intentar acceder a los registros centrales (`syslog.1`), el sistema denegó la lectura, requiriendo el uso de `sudo` (Super User DO).


```

Applications: logstash-tutorial.log lab.support.files - F... Terminal - analyst@se... Thu 28 May, 08:07 analyst
Terminal - analyst@secOps~
Apr 20 06:10:55 secOps kernel: [ 1.941729] fb: switching to vboxdmfb from VESA VGA
Apr 20 06:10:55 secOps kernel: [ 1.941746] Console: switching to colour dummy device 80x25
Apr 20 06:10:55 secOps kernel: [ 1.942421] fbcon: vboxdmfb (fb0) is primary device
Apr 20 06:10:55 secOps kernel: [ 1.943104] Console: switching to colour frame buffer device 100x37
Apr 20 06:10:55 secOps kernel: [ 1.946063] vboxdmfb 0000:00:02.0: fb0: vboxdmfb frame buffer device
Apr 20 06:10:55 secOps kernel: [ 1.948800] [drm] Initialized vboxdmfb 1.0.0 20130823 for 0000:00:02.0 on minor 0
Apr 20 06:10:55 secOps kernel: [ 2.325167] clocksource: Switched to clocksource tsc
Apr 20 06:10:55 secOps kernel: [ 2.657693] ACPI: AC Adapter [AC] (on-line)
Apr 20 06:10:55 secOps kernel: [ 2.679946] ACPI: Battery Slot [BAT0] (battery present)
Apr 20 06:10:55 secOps kernel: [ 2.715300] piix4_smbus 0000:00:07.0: SMBus Host Controller at 0x4100, revision 0
Apr 20 06:10:55 secOps kernel: [ 2.719334] input: PC Speaker as /devices/platform/pcspkr/input/input5
Apr 20 06:10:55 secOps kernel: [ 2.726126] rtc_cmos rtc_cmos: rtc core: registered rtc_cmos as rtc0
Apr 20 06:10:55 secOps kernel: [ 2.726233] rtc_cmos rtc_cmos: alarms up to one day, 114 bytes nvram
Apr 20 06:10:55 secOps kernel: [ 2.741539] pcnet32: pcnet32.c:v1.35 21.Apr.2008 tsbogend@alpha.franken.de
Apr 20 06:10:55 secOps kernel: [ 2.742123] pcnet32: PCnet/FAST III 79C973 at 0xd000, 08:00:27:23:b2:31 assigned IRQ 19
Apr 20 06:10:55 secOps kernel: [ 2.742159] pcnet32: Found PHY 0022:561b at address 0
Apr 20 06:10:55 secOps kernel: [ 2.748256] pcnet32: eth0: registered as PCnet/FAST III 79C973
Apr 20 06:10:55 secOps kernel: [ 2.748308] pcnet32: 1 cards_found
Apr 20 06:10:55 secOps kernel: [ 2.777072] RAPL PMU: API unit is 2^-32 Joules, 5 fixed counters, 10737418240 ms ovfl timer
Apr 20 06:10:55 secOps kernel: [ 2.777074] RAPL PMU: hw unit of domain pp0-core 2^-0 Joules
Apr 20 06:10:55 secOps kernel: [ 2.777074] RAPL PMU: hw unit of domain package 2^-0 Joules
Apr 20 06:10:55 secOps kernel: [ 2.777075] RAPL PMU: hw unit of domain dram 2^-0 Joules
Apr 20 06:10:55 secOps kernel: [ 2.777076] RAPL PMU: hw unit of domain ppl-gpu 2^-0 Joules
Apr 20 06:10:55 secOps kernel: [ 2.777077] RAPL PMU: hw unit of domain psys 2^-0 Joules
Apr 20 06:10:55 secOps kernel: [ 2.923401] pcnet32 0000:00:03.0 enp0s3: renamed from eth0
Apr 20 06:10:55 secOps kernel: [ 2.953163] pcnet32 0000:00:03.0 enp0s3: link up, 100Mbps, full-duplex
Apr 20 06:10:55 secOps kernel: [ 2.984802] psmouse serio1: hgpk: ID: 10 00 64
Apr 20 06:10:55 secOps kernel: [ 2.986439] input: ImEXPS/2 Generic Explorer Mouse as /devices/platform/i8042/serio1/input/i
nput6
Apr 20 06:10:55 secOps kernel: [ 3.009683] mousedev: PS/2 mouse device common for all mice
Apr 20 06:10:55 secOps kernel: [ 4.721266] nf_conntrack version 0.5.0 (16384 buckets, 65536 max)
Apr 20 06:10:55 secOps kernel: [ 4.979025] openvswitch: Open vSwitch switching datapath
[analyst@secOps ~]$

```

Figura 8: Auditoría de registros del sistema mediante escalada de privilegios.

¿Por qué el comando cat tuvo que ejecutarse como root?

El principio de Menor Privilegio (PoLP). El archivo `syslog` documenta eventos del Kernel, fallos de montaje de hardware, y más importante, rastros de autenticación (quién entró, a qué hora, qué comandos se ejecutaron). Si un atacante lograra vulnerar un usuario estándar no privilegiado, la restricción de lectura de estos logs impide que realice un reconocimiento interno (Reconnaissance) o que borre sus huellas.

La infraestructura utiliza rotación de logs (Log Rotation) para prevenir que los archivos de texto colapsen el almacenamiento físico (*Out of Space*). A continuación se auditaron los archivos históricos rotados `syslog.2`, `syslog.3` y `syslog.4`:

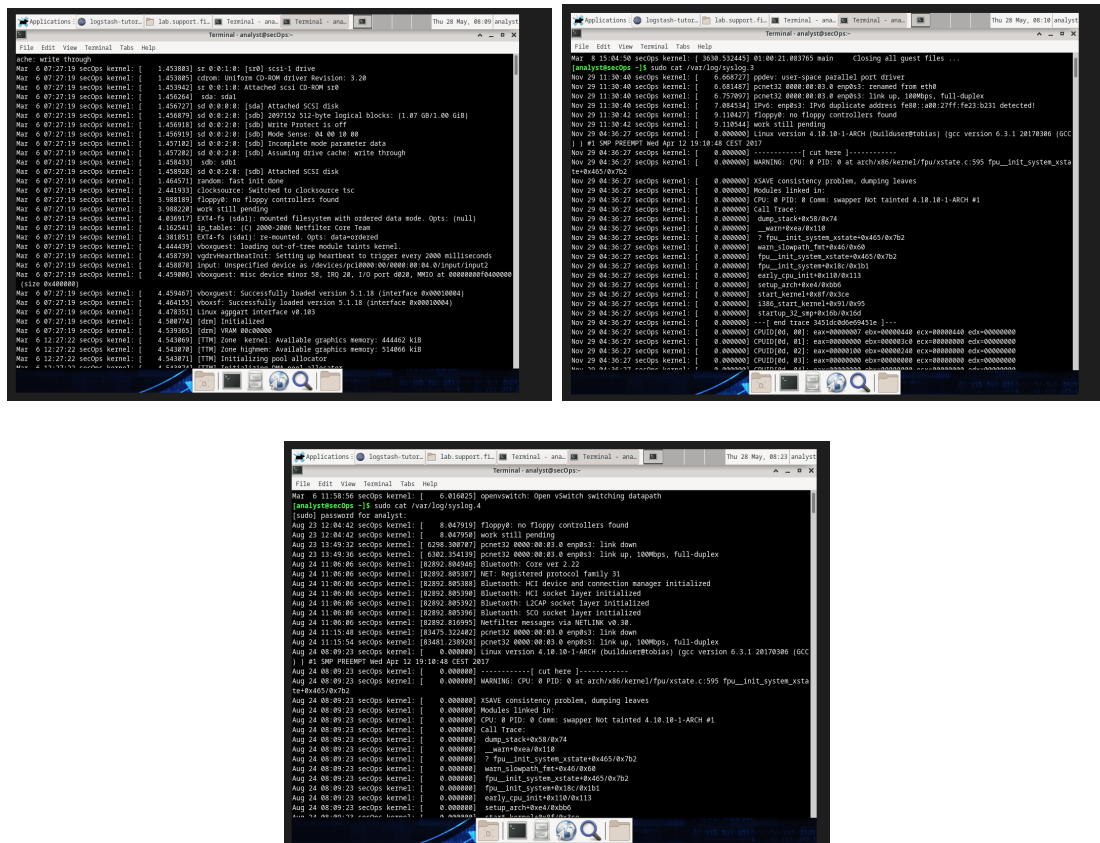


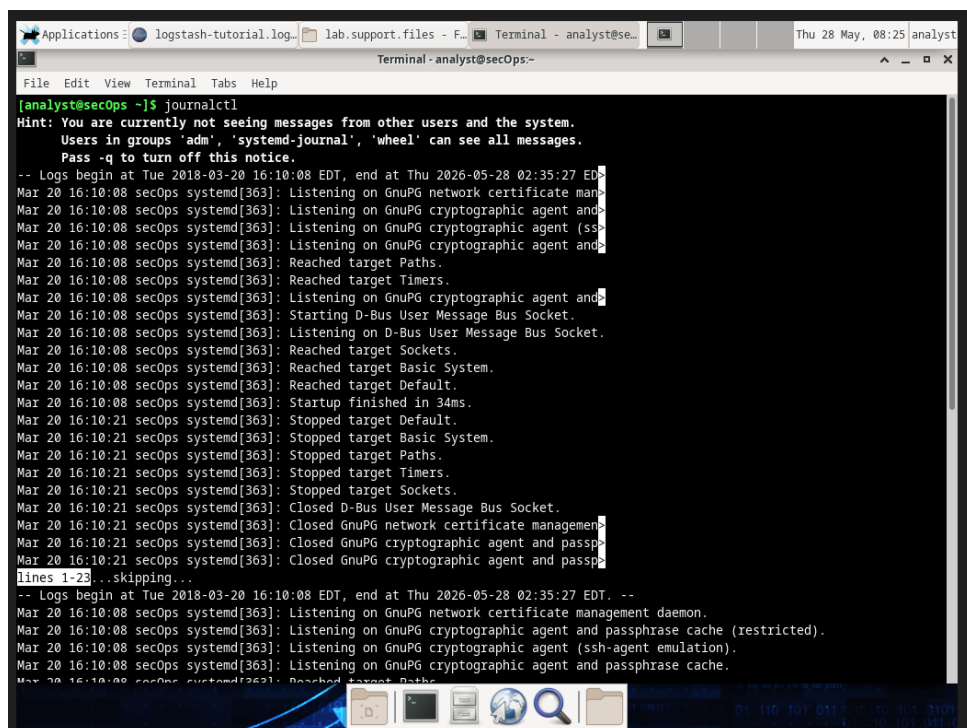
Figura 9: Examen de archivos rotados y empaquetados por el demonio logrotate.

¿Por qué es tan importante mantener la fecha y la hora de los computadores correctamente sincronizadas?

El impacto de un reloj desfasado es catastrófico para la correlación de eventos. En la respuesta a incidentes, los ataques suelen ser cadenas complejas (ej. Infección a las 10:00:01, Escalamiento a las 10:00:03, Exfiltración a las 10:00:10). Si el servidor Web tiene una hora distinta a la del Servidor de Base de Datos, el SIEM (Gestor de Seguridad) será incapaz de trazar la ruta de ataque linealmente. El uso del protocolo NTP (Network Time Protocol) es un requisito normativo ineludible para garantizar la validez legal de las pruebas informáticas.

2.2.4. La Evolución: Archivos de registro y Journalctl

Los entornos basados en Systemd abandonan los logs en texto plano en favor del demonio journald. Este sistema indexa los registros en una base de datos binaria altamente estructurada.



```
[analyst@secOps ~]$ journalctl
Hint: You are currently not seeing messages from other users and the system.
      Users in groups 'adm', 'systemd-journal', 'wheel' can see all messages.
      Pass -q to turn off this notice.
-- Logs begin at Tue 2018-03-20 16:10:08 EDT, end at Thu 2026-05-28 02:35:27 EDT. --
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG network certificate man
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG cryptographic agent and
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG cryptographic agent (ss
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG cryptographic agent and
Mar 20 16:10:08 secOps systemd[363]: Reached target Paths.
Mar 20 16:10:08 secOps systemd[363]: Reached target Timers.
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG cryptographic agent and
Mar 20 16:10:08 secOps systemd[363]: Starting D-Bus User Message Bus Socket.
Mar 20 16:10:08 secOps systemd[363]: Listening on D-Bus User Message Bus Socket.
Mar 20 16:10:08 secOps systemd[363]: Reached target Sockets.
Mar 20 16:10:08 secOps systemd[363]: Reached target Basic System.
Mar 20 16:10:08 secOps systemd[363]: Reached target Default.
Mar 20 16:10:08 secOps systemd[363]: Startup finished in 34ms.
Mar 20 16:10:21 secOps systemd[363]: Stopped target Default.
Mar 20 16:10:21 secOps systemd[363]: Stopped target Basic System.
Mar 20 16:10:21 secOps systemd[363]: Stopped target Paths.
Mar 20 16:10:21 secOps systemd[363]: Stopped target Timers.
Mar 20 16:10:21 secOps systemd[363]: Stopped target Sockets.
Mar 20 16:10:21 secOps systemd[363]: Closed D-Bus User Message Bus Socket.
Mar 20 16:10:21 secOps systemd[363]: Closed GnuPG network certificate management
Mar 20 16:10:21 secOps systemd[363]: Closed GnuPG cryptographic agent and passp
Mar 20 16:10:21 secOps systemd[363]: Closed GnuPG cryptographic agent and passp
lines 1-23 ...skipping...
-- Logs begin at Tue 2018-03-20 16:10:08 EDT, end at Thu 2026-05-28 02:35:27 EDT. --
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG network certificate management daemon.
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG cryptographic agent and passphrase cache (restricted).
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG cryptographic agent (ssh-agent emulation).
Mar 20 16:10:08 secOps systemd[363]: Listening on GnuPG cryptographic agent and passphrase cache.
Mar 20 16:10:08 secOps systemd[363]: Reached target Paths.
```

Figura 10: Vista estandarizada de la base de datos de logs mediante journalctl.

La potencia de `journalctl` reside en sus capacidades de consulta sintáctica (*Querying*). Se experimentó con múltiples parámetros de filtrado forense:

- `journalctl --utc`: Normaliza todas las marcas de tiempo al meridiano de Greenwich (UTC). Crítico para empresas transnacionales.
- `journalctl -b`: (*Boot*) Filtra agresivamente la base de datos para mostrar única y exclusivamente los eventos que ocurrieron desde el último reinicio del servidor, descartando meses de datos irrelevantes.
- `journalctl -k`: (*Dmesg/Kernel*) Suprime los mensajes de aplicaciones (Capa 7) y aísla los mensajes del anillo cero (Ring 0) del sistema operativo, vital para diagnosticar fallos de hardware o pánicos del núcleo (*Kernel Panics*).
- `journalctl -u nginx.service`: Aísla los registros pertenecientes exclusivamente a una unidad de servicio (en este caso el servidor web Nginx).

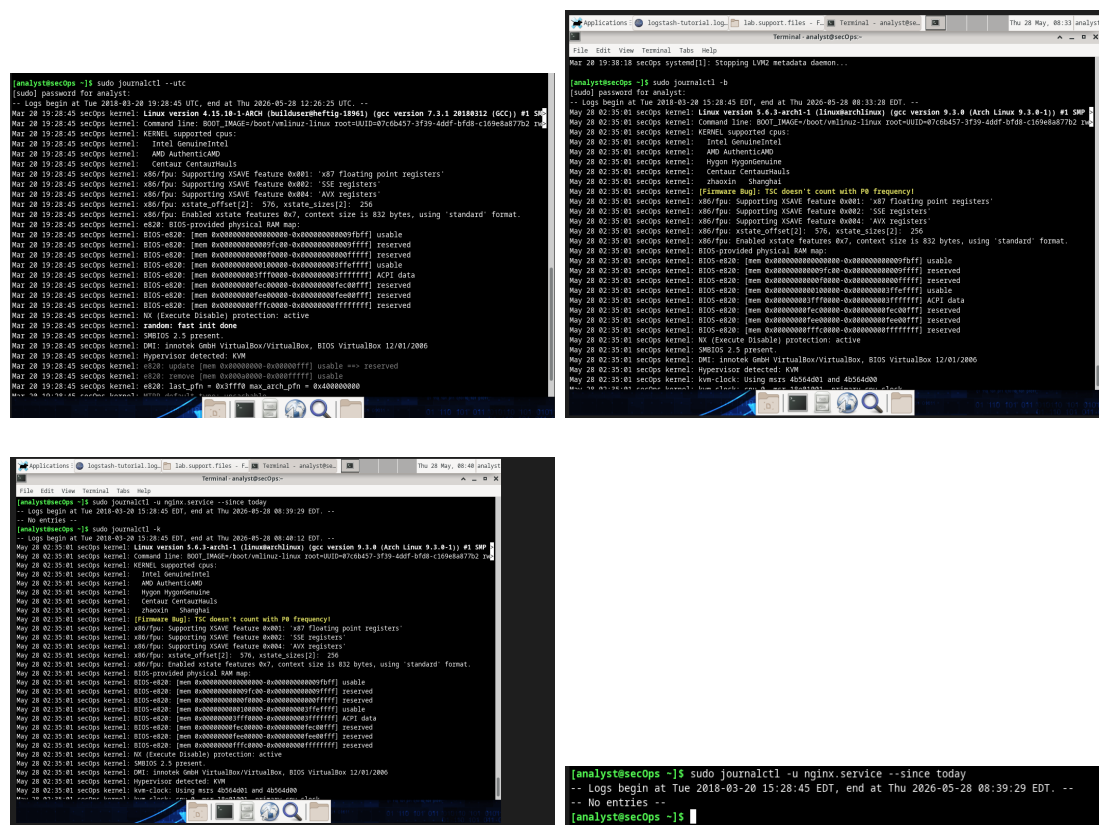


Figura 11: Aplicación de la doctrina de filtrado técnico con modificadores journalctl.

Reflexión Técnica: Compare Syslog y Journald. ¿Cuáles son las ventajas y desventajas de cada uno?

- **Syslog (El Estándar Clásico):** Su ventaja definitiva es la ubicuidad y la simplicidad. Al ser archivos de texto en texto claro (Plaintext), pueden ser procesados mediante potentes herramientas tradicionales de UNIX (`grep`, `awk`, `sed`) y exportados a cualquier SIEM sin adaptadores complejos. Su desventaja recae en la falta de metadatos integrados; la manipulación o parseo de logs requiere el uso de expresiones regulares densas y propensas a errores.
- **Journald (El Enfoque Moderno):** Su inmensa ventaja es la integridad y el filtrado metadato. Al ser binario, permite consultar logs por PID (Process ID), UID (Usuario) o UUID de máquina instantáneamente. Incluso soporta salida nativa en formato JSON (`-o json`), ideal para ingestas en APIs modernas. Su desventaja es la opacidad: si el binario del journal se corrompe, el administrador no puede recuperar los logs abriéndolos con un bloc de notas simple; se requiere obligatoriamente una herramienta en funcionamiento compatible con la firma binaria de Systemd.

2.3. Práctica 3: Manejo de Incidentes (Estudio de Caso Analítico)

El escenario plantea una crisis sistémica: Una empresa financiera de 100 empleados es víctima de la propagación incontrolada de un gusano informático de tipo Día Cero (*Zero-Day*) distribuido vía dispositivos de almacenamiento USB y medios compartidos de

Windows (Protocolo SMB/CIFS). El malware incluye un *payload* (carga útil) que transforma las estaciones de trabajo en agentes "Zombis" dentro de una Botnet para ejecutar ataques de Denegación de Servicio Distribuido (DDoS). Los motores antivirus clásicos basados en firmas (*Signature-based*) fueron ineficaces durante horas.

Para abordar este incidente, se deben responder las preguntas estratégicas del modelo de respuesta a incidentes (NIST SP 800-61), estructurando así nuestro plan de acción:

2.3.1. Fase 1: Preparación

- **¿La organización consideraría esta actividad como un incidente? Si es así, ¿cuál de las políticas de la organización viola esta actividad?**

Absolutamente. Se clasifica como un Incidente Crítico de Seguridad (Prioridad 1) debido a la interrupción operativa y al riesgo de participación involuntaria en un ciberataque externo (DDoS). Viola frontalmente las "Políticas de Uso Aceptable de Dispositivos Extraíbles (USB)", la "Política de Tráfico de Red Permitido" y la "Política de Seguridad de Endpoint".

- **¿Qué medidas existen para intentar evitar que este tipo de incidente vuelva a ocurrir o limitar su impacto?**

Para prevenir, se debe implementar una Política de Grupo (GPO) a nivel de Active Directory que bloquee el montaje de la clase `USBSTOR` (memorias USB no autorizadas). Para limitar el impacto, se debe forzar el aislamiento de red (Microsegmentación VLAN) y desplegar plataformas *Endpoint Detection and Response* (EDR, ej. SentinelOne, CrowdStrike) que bloquean malware por comportamiento anómalo, en lugar de depender de firmas de antivirus tradicionales.

2.3.2. Fase 2: Detección y Análisis

- **¿Qué precursores del incidente, si los hay, podría detectar la organización?**

Un precursor claro habría sido el registro de intentos masivos de conexión fallida a los puertos SMB (TCP 445) desde máquinas internas hacia recursos compartidos (comportamiento típico de un gusano mapeando la red).

- **¿Qué indicadores del incidente podría detectar la organización?**

Los indicadores principales (IoCs) incluyen: lentitud extrema de la red interna (causada por el tráfico lateral del gusano), alertas del Firewall perimetral reportando un inusual volumen de tráfico UDP/TCP saliente coordinado hacia direcciones IP externas desconocidas (el ataque DDoS), y picos de consumo de CPU/RAM al 100 % en las estaciones de los asesores.

- **¿Qué herramientas adicionales podrían ser necesarias para detectar este incidente en particular?**

Es imperativo el uso de un **SIEM** (Wazuh, Splunk) para centralizar la telemetría, y Sistemas de Detección de Intrusos (**NIDS** como Snort o Suricata) para analizar los paquetes en tránsito y levantar alertas sobre tráfico malicioso antes de que el antivirus local se percate.

- **¿Cómo priorizaría el equipo el manejo de este incidente?**

El incidente debe catalogarse como **Severidad Alta/Crítica**. El equipo debe priorizar primero detener el tráfico saliente (DDoS) para evitar daños legales y reputacionales (responsabilidad civil), y en segundo lugar, frenar la propagación lateral interna para salvar los servidores de bases de datos.

2.3.3. Fase 3: Contención, Erradicación y Recuperación

- **¿Qué estrategia debería tomar la organización para contener el incidente? ¿Por qué esta estrategia es preferible a otras?**

La estrategia de **Contención Dinámica (Aislamiento Lógico)** es la mejor. A través de la CLI del Switch, se envían los puertos de los equipos infectados a una *VLAN de Cuarentena* (sin enrutamiento a Internet ni a servidores internos). Es preferible a simplemente apagar los equipos porque permite mantener la RAM encendida para análisis forense, pero corta instantáneamente la hemorragia de datos y el ataque DDoS. Adicionalmente, el Firewall debe aplicar reglas de bloqueo forzoso (Drop) hacia la IP destino del ataque.

- **¿Qué herramientas adicionales podrían ser necesarias para responder a este incidente?**

Se requerirá **Wireshark** o **tcpdump** (a través de un puerto espejo SPAN en el switch) para capturar el tráfico y aislar la IP origen del "paciente cero".

- **¿Qué personal estaría involucrado?**

Administradores de Red (para aislar VLANs y aplicar reglas de Firewall), Analistas de Seguridad SOC/NOC (para analizar logs y trazar el origen), y personal de Soporte Técnico (*HelpDesk*) para asistir en la recuperación física de las máquinas.

- **¿Qué fuentes de evidencia debería adquirir la organización? ¿Cómo se obtendría y almacenaría?**

Se debe realizar un volcado de la memoria RAM (Memory Dump) de los equipos infectados antes de apagarlos (usando herramientas como FTK Imager), y recolectar los logs centralizados (**syslog**, Event Viewer) desde el SIEM. Esta evidencia debe almacenarse en un servidor seguro (*Cold Storage*) calculando su Hash (SHA-256) para garantizar la Cadena de Custodia. Debe conservarse el tiempo que dicte la normativa legal local (usualmente entre 1 y 5 años) ante posibles demandas del banco afectado por el DDoS.

2.3.4. Fase 4: Actividad Posterior al Incidente

- **¿Qué se podría hacer para evitar que ocurran incidentes similares en el futuro?**

Implementar el paradigma de **Zero Trust** (Confianza Cero), exigiendo autenticación multifactor (MFA) para moverse por la red interna. Modificar radicalmente las Políticas de Recursos Humanos imponiendo sanciones severas por conectar dispositivos personales. Deshabilitar los puertos USB mediante políticas del controlador de dominio (GPO).

- **¿Qué se podría hacer para mejorar la detección de incidentes similares?**

Afinar (Tuning) el Firewall y el SIEM para que apliquen bloqueos automatizados. Si

un nodo interno comienza a enviar más de 10,000 paquetes por segundo al exterior, la red debe aislarlo automáticamente sin esperar intervención humana. Reemplazar los antivirus estáticos por plataformas EDR impulsadas por Inteligencia Artificial.

3. Conclusiones

Tras finalizar esta rigurosa actividad práctica, puedo concluir lo siguiente:

En primera instancia, el manejo fluido de registros en sistemas UNIX/Linux mediante comandos como `tail -f` y `journalctl` trasciende el mero conocimiento teórico para convertirse en una competencia técnica crítica. Los entornos gráficos (GUI) colapsan o se vuelven ciegos ante ataques volumétricos; es en la interfaz de texto crudo donde el analista de ciberseguridad ejerce la auditoría real y el aislamiento de la falla. Entender las limitantes de carga en memoria de comandos como `cat` y `more` frente a la eficiencia forense de `less` separa a un usuario básico de un administrador avanzado.

En segunda medida, la gestión de incidentes expuso un axioma fundamental de las telecomunicaciones: la correlación es matemáticamente imposible sin relojes sincronizados (NTP). Ningún SIEM de alta tecnología puede reconstruir la cadena de tiempo de un vector de ataque si las estampas de tiempo (Timestamps) están corrompidas por disparidades geográficas.

Por último, frente al escrutinio del estudio de caso, destaco de manera categórica que la ciberseguridad es tridimensional (Personas, Procesos y Tecnología). La excesiva confianza en la respuesta pasiva del software antivirus fue lo que permitió que la botnet DDoS escalara impunemente. La seguridad contemporánea debe ser predictiva y estratificada. Se requiere la visibilidad granular que ofrecen los analizadores de tráfico (*Snort*, *Wireshark*) y una férrea disciplina corporativa para bloquear vectores primarios físicos (como los puertos USB vía GPO). Contener, erradicar y recuperar no son simples palabras, sino el resultado de un *Playbook* ensayado, financiado e integrado.

Referencias Bibliográficas y Técnicas

- [1] Gómez, Á. (2015). *Gestión de incidentes de seguridad informática*. RA-MA Editorial. Referenciado para las bases metodológicas de la instrumentación de políticas y procesos de contención.
- [2] Raya, L. y Raya, L. (2015). *Sistemas informáticos*. RA-MA Editorial. Citado para el estudio estructural de componentes de sistemas operativos Linux y su vinculación con procesos y anillos del kernel.
- [3] Chicano, E. (2015). *Gestión de incidentes de seguridad informática (MF0488-3)*. IC Editorial. Utilizado como marco referencial para establecer directrices de preparación técnica y auditoría en entornos locales.
- [4] Cichonski, P., Millar, T., Grance, T., y Scarfone, K. (2012). *Computer Security Incident Handling Guide* (NIST Special Publication 800-61 Rev. 2). National Institute of Standards and Technology. Estándar canónico implementado para estructurar de manera oficial el ciclo de vida analítico en el Caso de Estudio 3.
- [5] Whitehouse, D. (2014). *Blue Team Handbook: Incident Response Edition: A condensed field guide for the Cyber Security Incident Responder*. Análisis aplicado para sustentar la inyección de herramientas en línea de comandos (`grep`, `tcpdump`, `journalctl`) durante eventos de triaje forense activo.